

Laboratório SOC Analyst N1 — Investigação de Login Impossível (Impossible Travel)

Cenário

Sou analista SOC Nível 1 da empresa fictícia **GlobalTech**.

Durante meu turno, o SIEM gerou um alerta de **Impossible Travel** relacionado a uma conta corporativa do Microsoft 365.

O alerta indicava que o mesmo usuário realizou login:

- no Brasil
- e poucos minutos depois na Alemanha

Meu objetivo era:

- validar se houve comprometimento
- analisar os logins
- identificar IOC
- verificar atividades suspeitas
- escalar corretamente o incidente

Alerta recebido

Alert: Impossible Travel Activity

User: r.souza@globaltech.com

Severity: Medium

Login 1:

Location: São Paulo, Brazil

IP: 177.92.44.18

Time: 08:02 AM

Login 2:

Location: Frankfurt, Germany

IP: 185.193.126.44

Time: 08:19 AM

Primeira análise

Assim que visualizei o alerta, comecei avaliando:

Evidência	Motivo
países diferentes	comportamento anormal
intervalo curto	viagem impossível
login internacional	potencial comprometimento
conta corporativa	risco elevado

Minha hipótese inicial foi:

- possível comprometimento de credencial

Investigando no Splunk

Comecei pesquisando eventos relacionados ao usuário.

Pesquisa inicial no Splunk

index=o365 user="r.souza@globaltech.com"

Resultado:

08:02 Login Success

Country: Brazil

IP: 177.92.44.18

08:19 Login Success

Country: Germany

IP: 185.193.126.44

Refinando a investigação

Quis entender:

- se houve falhas antes do login
- se existia tentativa de força bruta

Pesquisa Splunk — falhas de autenticação

index=o365 user="r.souza@globaltech.com"

("Login Failed" OR "Authentication Failure")

Resultado:

08:15 Authentication Failure

IP: 185.193.126.44

08:17 Authentication Failure

IP: 185.193.126.44

08:19 Login Success

IP: 185.193.126.44

Minha análise

Nesse momento alguns pontos ficaram claros:

- o IP alemão realizou falhas antes do sucesso
- o comportamento parecia suspeito
- existia possibilidade de senha comprometida

Investigando no KQL

Se eu estivesse usando o Microsoft Sentinel seria assim:

Pesquisa KQL — logins do usuário

SigninLogs

| where UserPrincipalName == "r.souza@globaltech.com"

| project TimeGenerated,

IPAddress,

Location,

ResultType

| order by TimeGenerated asc

Resultado:

Brazil -> Success

Germany -> Failure

Germany -> Failure

Germany -> Success

Investigando MFA

Meu próximo passo foi verificar:

- o MFA foi utilizado?

Pesquisa KQL — MFA

SigninLogs

| where UserPrincipalName == "r.souza@globaltech.com"

| project TimeGenerated,

IPAddress,

AuthenticationRequirement

Resultado:

AuthenticationRequirement:

singleFactorAuthentication

Mudança na severidade

Isso aumentou bastante minha preocupação.

A conta:

- não possuía MFA ativo
- teve login internacional suspeito
- apresentou falhas antes do sucesso

Nesse momento comecei a considerar:

- comprometimento real de conta

Investigando atividade pós-login

Depois disso procurei:

- criação de regras de e-mail
- downloads
- acessos incomuns
- alterações de conta

Pesquisa Splunk — regras de encaminhamento

index=o365 user="r.souza@globaltech.com"
("New-InboxRule" OR "ForwardTo")

Resultado encontrado:

New Inbox Rule Created

Forward all emails to:
finance.audit@protonmail.com

Investigação aprofundada

Esse foi o principal indicador de comprometimento.

Criminosos frequentemente:

- criam regras ocultas
- desviam e-mails financeiros
- monitoram comunicações internas

IOC identificados

IP suspeito

185.193.126.44

Conta afetada

r.souza@globaltech.com

E-mail suspeito

finance.audit@protonmail.com

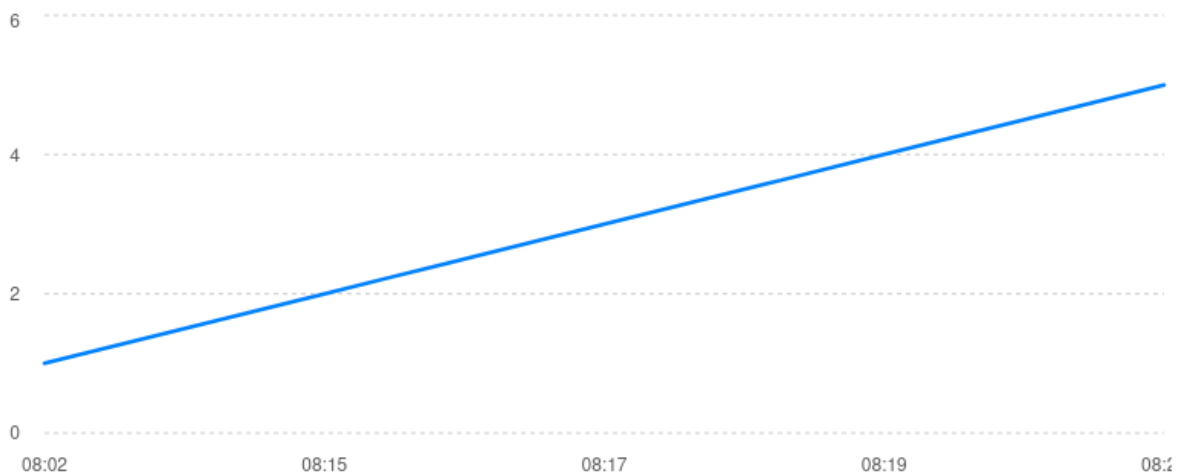
Minhas ações como SOC Analyst N1

Após validar o comprometimento:

- Escalei imediatamente para N2
- Solicitei reset de senha
- Solicitei ativação de MFA
- Registrei IOC
- Recomendei revogar sessões ativas
- Solicitei remoção da regra de encaminhamento

Timeline do incidente

Sequência dos eventos identificados durante a investigação.



Legenda:

- 1 = login Brasil
- 2 = falha Alemanha
- 3 = nova falha
- 4 = login sucesso Alemanha
- 5 = criação de regra de encaminhamento

Relatório SOC N1

Foi identificado alerta de Impossible Travel envolvendo a conta r.souza@globaltech.com.

Durante a investigação foram observados:

- login no Brasil
- múltiplas falhas de autenticação na Alemanha
- login bem-sucedido internacional
- ausência de MFA
- criação de regra suspeita de encaminhamento

IOC identificados:

- IP: 185.193.126.44
- Email externo: finance.audit@protonmail.com

Possível comprometimento de conta confirmado.
Incidente escalado para equipe N2.

O que aprendi nesse laboratório

- Como investigar Impossible Travel
- Como analisar logins Microsoft 365
- Como identificar comprometimento de conta
- Como investigar regras maliciosas de e-mail
- Como utilizar Splunk e KQL
- Como validar ausência de MFA
- Como coletar IOC



Autor: Paulo Cesar
Formado em Segurança da informação
[linkedin.com/in/paulo-cesar-security](https://www.linkedin.com/in/paulo-cesar-security)